

פרק 1 – מבוא לאיומי רשת חדשים

10 שעות עיוני • שבועות 1-3

איך לקרוא את הפרק הזה

הפרק נכתב כך שאפשר לקרוא אותו ברצף, מההתחלה ועד הסוף, גם אם מעולם לא למדתם רשתות מחשבים. כל מונח מוסבר בפעם הראשונה שהוא מופיע, ואין צורך בידע מוקדם. לאורך הדרך נעצור לסיפורים אמיתיים שקרו בעולם, ובסוף יש תרגילים עם פתרונות ומילון מונחים לחזרה מהירה.

1.1 על מה בכלל מדברים?

נתחיל מהשאלה הכי בסיסית: מה זה "אבטחת מידע"? **אבטחת מידע** (Information Security) היא פשוט ההגנה על מידע – ועל המחשבים שמחזיקים אותו – מפני אנשים שאסור להם לגשת אליו, לשנות אותו או למחוק אותו. המידע יכול להיות תמונות בטלפון שלכם, ציונים במערכת של בית הספר, או פרטי כרטיסי האשראי של לקוחות בחנות. הרעיון זהה בכל המקרים: יש משהו בעל ערך, ואנחנו רוצים שרק האנשים הנכונים יוכלו לגעת בו.

בקורס הזה נתמקד בתחום מסוים בתוך אבטחת המידע שנקרא **אבטחת רשת** (Network Security). "רשת" היא מה שמחבר מחשבים זה לזה כדי שיוכלו לדבר – למשל הרשת בבית שמחברת את הטלפון, המחשב והטלוויזיה החכמה לאינטרנט. אבטחת רשת עוסקת בהגנה על הצינורות שדרכם עובר המידע ועל המידע עצמו בזמן שהוא בדרך. למה דווקא הרשת? כי היום כמעט כל התקפה מגיעה דרך הרשת – תוקף בצד השני של העולם יכול לנסות להיכנס למחשב שלכם מבלי לקום מהכיסא.

1.2 אבני הבניין – המושגים שנשתמש בהם כל הזמן

לפני שנצלול, בואו נכיר כמה מילים בסיסיות. אל תדאגו – כולן פשוטות, ונחזור אליהן שוב ושוב.

- **מחשב מארח** (Host) – כל מכשיר שמחובר לרשת: מחשב, טלפון, שרת, מדפסת, ואפילו מצלמת אבטחה חכמה. בקיצור, כל דבר "שיוזע לדבר" ברשת.
- **כתובת IP** – ה"כתובת" של המכשיר ברשת, בדיוק כמו כתובת של בית (למשל. 192.168.1.10 לפי הכתובת הזו יודעים לאן לשלוח את המידע. שני מכשירים לא יכולים לתקשר בלי לדעת את הכתובת זה של זה.
- **כתובת MAC** – מספר סידורי ייחודי ש"צורב" בכרטיס הרשת של כל מכשיר עוד מהמפעל (למשל 0C:0E:15:22:05:97). אפשר לחשוב עליו כמו מספר השלדה של רכב – הוא מזהה את המכשיר עצמו, בעוד שכתובת ה-IP יכולה להשתנות.
- **חבילה** (Packet) – מידע ברשת לא נשלח כמקשה אחת גדולה, אלא נחתך ל"מעטפות" קטנות. כל מעטפה כזו נקראת חבילה, וכתובות עליה כתובת השולח וכתובת היעד – בדיוק כמו מעטפה בדואר.
- **שרת** (Server) ו**לקוח** (Client) – ה**לקוח** הוא מי שמבקש שירות (למשל הדפדפן שלכם), וה**שרת** הוא מי שנותן אותו (למשל המחשב שמאחסן את אתר האינטרנט). הלקוח שואל, השרת עונה.
- **נתב** (Router) – מכשיר שמעביר חבילות בין רשתות שונות, למשל בין הרשת בבית לבין האינטרנט. אפשר לחשוב עליו כעל צומת דרכים שמחליט לאן להפנות כל מעטפה.
- **מתג** (Switch) – מכשיר שמחבר מכשירים בתוך אותה רשת מקומית, למשל את כל המחשבים במשרד אחד.
- **פרוטוקול** (Protocol) – "שפה" או אוסף כללים מוסכמים שמכשירים מדברים בהם. למשל, HTTP הוא הפרוטוקול שבו דפדפנים ואתרים מדברים, ו-DNS הוא הפרוטוקול שמתרגם שם של אתר לכתובת IP. כמו כללי הנימוס בשיחת טלפון – שני הצדדים חייבים להסכים עליהם מראש.
- **פורט** (Port) – "דלת" ממוספרת בתוך מכשיר, אחת לכל סוג שירות. למשל דלת 80 לאתרי אינטרנט, דלת 443 לאתרים מאובטחים, דלת 22 לניהול מרחוק (SSH). לכל כתובת IP יש עשרות אלפי דלתות כאלה.

שימו לב לרעיון החשוב שמלווה את כל הקורס: בכל אחת מנקודות המפגש האלה – מכשיר, כתובת, חבילה, דלת – תוקף יכול לנסות להיכנס, ואנחנו נלמד איך לחסום אותו.

1.3 מה בעצם מגנים עליו? שלושת עקרונות ה-CIA

כשמדברים על אבטחת מידע, מגנים על שלושה דברים. הם כל כך מרכזיים שנוח לזכור אותם בראשי התיבות באנגלית – CIA – ונחזור אליהם בכל פרק בקורס.

סודיות (Confidentiality) פירושה שרק מי שמורשה יכול לראות את המידע. כשאתם בודקים את יתרת חשבון הבנק שלכם, רק אתם אמורים לראות אותה – זו סודיות. סודיות נפגעת כשמישהו "מצותת" לתקשורת שלכם או כשמאגר נתונים דולף. מגנים עליה בעזרת **הצפנה** (ערבוב המידע כך שרק בעל המפתח יבין אותו) ובקרת גישה.

שלמות (Integrity) פירושה שהמידע לא שונה בדרך בלי רשות. אם העברתם בבנק 1,000 ₪, אתם רוצים להיות בטוחים שאף אחד לא שינה את הסכום ל-10,000 ₪ באמצע הדרך. שלמות נפגעת כשתוקף מצליח לשנות מידע במעבר. מגנים עליה בעזרת **גיבוב** (טביעת אצבע דיגיטלית של המידע שנלמד בפרק 7) וחתימה דיגיטלית.

זמינות (Availability) פירושה שהמידע והשירות זמינים כשצריך אותם. הכספומט צריך לעבוד כשאתם רוצים למשוך מזומן, ואתר בית הספר צריך לעבוד ביום ההרשמה. זמינות נפגעת כשתוקף מפיל שירות (התקפת מניעת שירות, שנכיר בהמשך) או כשכופרה מצפינה את הקבצים.

למה שלושה ולא אחד?

תלמידים רבים חושבים שאם רק נצפין הכול, נהיה מוגנים. אבל הצפנה נותנת רק סודיות. קובץ מוצפן עדיין יכול להימחק (פגיעה בזמינות) או להיות מוחלף (פגיעה בשלמות). למעשה, **כופרה** – אחת הנוזקות המסוכנות היום – משתמשת בהצפנה נגדכם: היא מצפינה את הקבצים שלכם ודורשת כסף כדי לפתוח אותם. אותו כלי בדיוק יכול להיות הגנה או נשק. לכן צריך לחשוב על שלושת העקרונות יחד.

לצד שלושת אלה יש שני מושגים נלווים שכדאי להכיר: **אימות (Authentication)** – להוכיח מי אתה (למשל בעזרת שם משתמש וסיסמה), ו**אי-הכחשה (Non-repudiation)** – לוודא שמי ששלח הודעה לא יוכל אחר כך להכחיש ששלח אותה (מושג בעזרת חתימה דיגיטלית).

1.4 שפת הסיכון: נכס, פגיעות, איום, סיכון ובקרה

כדי לדבר על אבטחה בצורה מסודרת, אנשי המקצוע משתמשים בכמה מונחים קבועים. הדרך הכי קלה לזכור אותם היא דרך משל פשוט: **בית**.

- **נכס (Asset)** – הדבר בעל הערך שרוצים להגן עליו. במשל: הבית עצמו. באבטחת מידע: המידע של הלקוחות, השרתים, ואפילו המוניטין של החברה.
- **פגיעות (Vulnerability)** – חולשה שאפשר לנצל. במשל: חלון שנשאר פתוח. באבטחת מידע: סיסמה חלשה, תוכנה עם באג, או דלת (פורט) שנשארה פתוחה. הפגיעות היא מה שונתטילשב – אנחנו יכולים לסגור את החלון.
- **איום (Threat)** – הגורם שעלול לנצל את הפגיעות. במשל: הגנב. באבטחת מידע: האקר, נזקה, עובד ממורמר, ואפילו שריפה או הצפה. איומים קיימים תמיד ואינם בשליטתנו – גנבים קיימים בעולם בין אם נרצה ובין אם לא.
- **ניצול (Exploit)** – הדרך המדויקת שבה האיום מנצל את הפגיעות. במשל: הרגע שבו הגנב מטפס דרך החלון הפתוח.
- **סיכון (Risk)** – ההסתברות שהאיום אכן ינצל את הפגיעות, כפול הנזק שייגרם. אפשר לרשום זאת כנוסחה פשוטה: **סיכון = איום × פגיעות × ערך הנכס**. אם אחד מהם אפס, אין סיכון.
- **בקרה (Control)** – כל אמצעי שמקטין את הסיכון. במשל: הסורג על החלון. באבטחת מידע: חומת אש, הצפנה, נוהל בחברה, או מנעול על חדר השרתים.

המסקנה המעשית: אנחנו לא יכולים לבטל את האיומים (הגנבים תמיד יהיו שם), אבל אנחנו כן יכולים לצמצם פגיעויות (לסגור את החלונות) ולהוסיף בקורות (להתקין סורגים). זו כל התורה של ניהול סיכונים, שנרחיב עליה בפרק 9.

1.5 איך הגענו לכאן? קצת היסטוריה

האיומים על הרשת התפתחו יחד עם האינטרנט. בהתחלה, בשנות ה-80 וה-90, האיומים היו סקרנות של חובבנים. עם השנים הם הפכו לעסק של פשע מאורגן ואפילו לכלי מלחמה בין מדינות. במקום להקריא רשימת תאריכים, בואו נבין את המגמה דרך שני סיפורים אמיתיים.

1988 – הסטודנט שהפיל את האינטרנט (תולעת מוריס)

רוברט מוריס, סטודנט בן 23, כתב תוכנה קטנה "כדי למדוד את גודל האינטרנט". התוכנה הייתה אמורה להעתיק את עצמה למחשב פעם אחת בלבד – אבל בגלל באג היא הדביקה כל מחשב שוב ושוב, עד שכל מחשב

הריץ מאות עותקים של עצמו וקָרס. התוצאה: כ-6,000 מחשבים – עשירית מהאינטרנט של אותם ימים – הושבתו. מוריס היה האדם הראשון שהורשע בחוק הפריצה האמריקאי; היום הוא פרופסור מכובד ב-MIT. הסיפור מלמד שני דברים: שקוד יכול להתפשט לבד ברשת, ושלפעמים הנזק הגדול נגרם דווקא מטעות ולא מכוונה זדונית.

2017 – בית החולים שביטל ניתוחים (WannaCry)

בבוקר יום שישי אחד, מסכי המחשבים ב-80 בתי חולים ברחבי אנגליה הפכו לאדומים והציגו הודעה: "הקבצים שלך הוצפנו. שלם 300 דולר בביטקוין". מערכות התורים, תוצאות הבדיקות ומכשירי ההדמיה הפסיקו לעבוד; 19,000 תורים וניתוחים בוטלו, ואמבולנסים הופנו לבתי חולים אחרים. הנוזקה, כופרה בשם WannaCry, נכנסה דרך חולשה בתוכנת Windows שחברת מיקרוסופט מדוק מיישדוח הנקית רבב – אבל בתי החולים לא התקינו את העדכון. הלקח: עדכון תוכנה הוא אמצעי אבטחה, לא מטרד, ופגיעה בזמינות יכולה לעלות בחיי אדם.

1.6 מי הם התוקפים ומה הם רוצים?

לא כל התוקפים דומים. חשוב להבחין ביניהם לפי שני דברים: מה **המניע** שלהם (למה הם תוקפים) ומה **היכולת** שלהם (כמה הם מתוחכמים).

- Script Kiddie ("ילד סקריפטים") – חובבן שמריץ כלי פריצה שאחרים כתבו, בלי להבין באמת איך הם עובדים. המניע: סקרנות, יוקרה, שעמום. היכולת נמוכה, אבל הכלים שהוא מוריד מהאינטרנט יכולים להיות חזקים מאוד.
 - Hacktivist ("האקטיביסט") – תוקף ממניעים אידיאולוגיים או פוליטיים, למשל כדי למחות נגד ארגון. הקבוצה המפורסמת ביותר היא Anonymous, שהשחיתה אתרים והפילה שרתים מסיבות פוליטיות.
 - **פשע מאורגן** (Organized Crime) – קבוצה מאורגנת שמטרתה כסף. כנופיות כופרה כמו LockBit ו-REvil סוחטות מארגונים מיליוני דולרים. זהו כיום האיום הנפוץ והמזיק ביותר לעסקים.
 - **איום פנימי** (Insider) – עובד או קבלן שיש לו כבר גישה מורשית, והוא משתמש בה לרעה – מתוך נקמה, כסף, או סתם רשלנות. זהו האיום המסוכן במיוחד, כי "האויב כבר בפנים ויש לו מפתח". הדוגמה המפורסמת היא אדוארד סנודן, עובד שהדליף מסמכים סודיים של ה-NSA.
 - **מדינה** (State-sponsored) – יחידות סייבר ממשלתיות שתוקפות למטרות ריגול או חבלה בתשתיות. אלה התוקפים המתוחכמים ביותר, עם משאבים אדירים וסבלנות של שנים. הדוגמה המפורסמת היא Stuxnet, נוזקה שפגעה בצנטריפוגות במתקן גרעיני באיראן.
- הערה על מילים: לצד החלוקה לפי מניע, נהוג לחלק האקרים לפי אתיקה. White hat ("כובע לבן") הוא האקר שפועל באישור, למשל כדי לבדוק חדירות ולעזור לארגון להתגונן. Black hat ("כובע שחור") הוא פושע. Gray hat ("כובע אפור") פורץ בלי אישור אבל מדווח על מה שמצא. המילה "האקר" עצמה במקור פירושה מי שמבין מערכות לעומק – לא בהכרח פושע.

1.7 נוזקות: וירוסים, תולעים, סוסים טרויאנים ועוד

נוזקה (Malware) היא מילה כללית לכל תוכנה זדונית. שלושת הסוגים הקלאסיים נבדלים זה מזה בעיקר בשאלה אחת: סיטשפתם מה היא.

- **וירוס** (Virus) – קוד זדוני שנצמד לקובץ או לתוכנה קיימת. הוא מתפשט רק כאשר שמתשמה מריץ את הקובץ הנגוע (למשל פותח קובץ Excel נגוע). הוירוס משכפל את עצמו.
- **תולעת** (Worm) – תוכנה עצמאית שמשכפלת ומתפשטת תשרב דבל, בלי שאף אדם יעשה דבר. תולעת מוריס מ-1988 היא דוגמה מושלמת.
- **סוס טרויאני** (Trojan) – תוכנה שנראית לגיטימית ומפתה (למשל "משחק חינם"), אבל בתוכה מסתתר קוד זדוני. ונוצרם התוא ניקתם שמתשמה כי הוא חושב שהיא בסדר. בניגוד לוירוס ולתולעת, סוס טרויאני **אינו משכפל את עצמו**.

השאלה שפותרת הכול

כשמתלבטים בין וירוס לתולעת, שאלו את עצמכם: **האם צריך פעולה של משתמש כדי שהנוזקה תתפשט?**

אם כן – זה וירוס. אם היא מתפשטת לבד ברשת – זו תולעת. וסוס טרויאני? אותו המשתמש מתקין במו ידיו, והוא לא משכפל את עצמו.

מלבד השלושה הקלאסיים, כדאי להכיר עוד כמה נזקות בשמן: **כופרה** (Ransomware) מצפינה את הקבצים ודורשת תשלום (הנזקה המזיקה ביותר כיום); **רוגלה** (Spyware) ו-Keylogger מרגלות ומתעדות כל הקשה על המקלדת; Rootkit מתחבאת עמוק בתוך מערכת ההפעלה כדי שיהיה קשה מאוד לגלות אותה; Botnet הוא צבא של מחשבים נגועים ("זומבים") שהתוקף שולט בהם מרחוק ומפעיל אותם יחד; ו-Backdoor ("דלת אחורית") הוא פתח סמוי שעוקף את מנגנון האימות ומאפשר לתוקף להיכנס מתי שירצה.

2017 – הכופרה שלא הייתה כופרה (NotPetya)

NotPetya נראתה כמו כופרה רגילה, אבל למעשה הייתה נזקה מסוג Wiper – היא מחקה את המידע לצמיתות בלי אפשרות לשחזר, גם אם שילמת. היא התפשטה בצורה מפתיעה: דרך עדכון תוכנה ימיטיגל של תוכנת הנהלת חשבונות פופולרית באוקראינה (מה שנקרא "מתקפת שרשרת אספקה"). תוך שעות היא שיתקה חברות ענק כמו חברת הספנות Maersk, חברת התרופות Merck ו-FedEx, וגרמה נזק של כ-10 מיליארד דולר. הלקח: נזקה יכולה להיכנס דרך תוכנה שאתם סומכים עליה ומתעדכנת אוטומטית, ולא רק דרך קליק שלכם.

מול כל אלה, ההגנה הבסיסית מפני נזקות היא כמה שכבות יחד: **אנטי-וירוס** (שמזהה נזקות מוכרות לפי "חתימה" – אבל לא מזהה נזקה חדשה לגמרי), **עדכוני מערכת** שסוגרים חולשות, **גיבוי** שהוא התשובה מספר אחת לכופרה, ומעל הכול – משתמש ערני שלא לוחץ על כל קישור. הרעיון של כמה שכבות עצמאיות נקרא **הגנה לעומק** (Defense in Depth): אם שכבה אחת נכשלת, האחרות עדיין מגנות. הוא יחזור לאורך כל הקורס.

1.8 איך נראית התקפה מההתחלה עד הסוף

רוב ההתקפות עוברות שלושה שלבים. אפשר לחשוב עליהם כמו על פורץ שמתכנן שוד: קודם הוא משגיח על הבית, אחר כך מוצא דרך פנימה, ולבסוף לוקח את מה שרצה.

שלב 1 – סיור (Reconnaissance): התוקף לומד על המטרה. מי היא? אילו כתובות IP יש לה? אילו "דלתות" (פורטים) פתוחות? בשלב הזה תוקף משתמש בכלים כמו Nmap – תוכנה שסורקת רשת ומגלה אילו מכשירים חיים ואילו שירותים פועלים בהם. הסיור יכול להיות גם פסיבי (לחפש מידע גלוי על החברה באינטרנט) וגם אקטיבי (לשלוח חבילות ולראות מה חוזר).

שלב 2 – השגת גישה (Access): התוקף מנצל מה שגילה כדי להיכנס. הדרכים הנפוצות: ניחוש סיסמה, ניצול חולשה בתוכנה, או Man-in-the-Middle (MITM) – התוקף מכניס את עצמו באמצע התקשורת בין שני צדדים ומקשיב או משנה אותה.

שלב 3 – הנזק: כאן התוקף עושה את מה שרצה – גונב מידע, מצפין אותו בכופרה, או מפיל את השירות כדי שאף אחד לא יוכל להשתמש בו. השלב האחרון מוביל אותנו לסוג התקפה חשוב שכדאי להבין לעומק.

מניעת שירות – DoS ו-DDoS

מניעת שירות (Denial of Service, DoS), **בקיזור** DoS היא התקפה שמטרתה להפיל שירות כדי שלא יהיה זמין. הדרך הפשוטה: להציף את השירות בכל כך הרבה בקשות מזויפות עד שהוא קורס תחת העומס. כשההצפה מגיעה ממקור אחד קוראים לזה DoS; כשהיא מגיעה ביפלאמ תינמז מחשבים נגועים (botnet) קוראים לזה DDoS (Distributed DoS). אנלוגיה: אם מאה אנשים יזמינו במקביל משלוח פיצה לכתובת שלכם, המשלוח האמיתי שהזמנתם לא יוכל להגיע. קשה מאוד לחסום DDoS, כי אין כתובת אחת לחסום – ההתקפה מגיעה מכל מקום.

2016 – הצבא של מצלמות האבטחה (Mirai)

נזקה בשם Mirai השתלטה על כ-600,000 מכשירים פשוטים – מצלמות אבטחה, ראוטרים ביתיים ומקליטי וידאו. איך? היא פשוט ניסתה 62 צירופים של שם משתמש וסיסמה מברירת המחדל של היצרנים (כמו admin/admin, root/12345) – ואצל מי שלא שינה את הסיסמה, נכנסה. עם הצבא העצום הזה היא ביצעה DDoS שהפיל את Twitter, Netflix, Spotify ו-PayPal ליום שלם. הסיפור ממחיש בדיוק כמה מסוכנת סיסמת ברירת מחדל שלא שונתה, ומהו botnet בפועל.

יש כמה שיטות עיקריות לבצע התקפת מניעת שירות, וכדאי להכיר אותן בשמן כי הן חוזרות בשאלות:

- **SYN Flood** – כדי לפתוח חיבור TCP, הלקוח והשרת מבצעים "לחיצת יד" של שלושה שלבים (הלקוח שולח SYN, השרת עונה SYN-ACK, הלקוח משיב ACK). בהתקפה הזו התוקף שולח המוני הודעות SYN אך

פילשם אל סלועל את השלב השלישי. השרת שומר מקום לכל חיבור "חצי-פתוח" עד שהזיכרון שלו מתמלא ולקוחות אמיתיים נדחים. אנלוגיה: מישהו שמתקשר שוב ושוב, השרת עונה "הלו?", והמתקשר שותק – עד שכל הקווים תפוסים.

- **Ping of Death** – שליחת חבילת ("CMP|פינג") גדולה מהמותר, שגרמה בעבר למערכות לקרוס בעת הרכבתה מחדש. היום מתוקן, אך עדיין מופיע בשאלות היסטוריות.
- **Smurf** – התוקף שולח פינג לכתובת "שידור" (broadcast) של רשת שלמה, אבל מזייף את כתובת המקור כך שתהיה של הקורבן. כל המחשבים ברשת עונים בבת אחת – לקורבן. כך תוקף קטן "מגייס" רשת שלמה כדי להציף מטרה (הגברה).
- **הגברה (Amplification)** – אותו רעיון של Smurf, בגרסה מודרנית: התוקף שולח שאילתה קטנה לשרת (למשל DNS) עם כתובת מקור מזויפת של הקורבן, והשרת מחזיר לקורבן תשובה גדולה בהרבה. יחס ההגברה יכול להיות פי 50 ויותר.

מלבד מניעת שירות, כדאי להכיר עוד שתי התקפות "גישה" נפוצות שנשאלות: **Buffer Overflow** (גלישת חוצץ) – כל תוכנה שומרת קלט באזור זיכרון בגודל קבוע ("חוצץ"). אם התוקף שולח קלט צפוחהמ כורא, העודף "גולש" ודורס אזורי זיכרון סמוכים – ואם התוקף מתכנן זאת בקפידה, הוא יכול לגרום למחשב להריץ קוד משלו. ההגנה: עדכוני תוכנה ובדיקת אורך הקלט. ו-**Man-in-the-Middle (MITM)** ("אדם באמצע") – התוקף מכניס את עצמו בין שני צדדים המתקשרים, כך שכל מה שאחד שולח עובר דרכו לפני שמגיע לשני. כך הוא יכול לצותת (לפגוע בסודיות) או לשנות הודעות (לפגוע בשלמות). ההגנה העיקרית: הצפנה עם אימות – אם התעבורה מוצפנת, המאזין רואה רק ג'יבריש.

סיסמאות והתקפת ניחוש

אחת הדרכים הנפוצות להיכנס היא פשוט לנחש את הסיסמה. **התקפת ברוט-פורס (Brute Force)** מנסה באופן שיטתי את כל הצירופים האפשריים עד שהיא מוצאת את הנכון; גרסה נפוצה שלה, **התקפת מילון**, מנסה קודם רשימה של סיסמאות נפוצות. כאן נכנס עיקרון פשוט וחשוב: **אורך הסיסמה חשוב יותר ממורכבותה**. סיסמה של 6 ספרות נפרצת בפחות משנייה; סיסמה של 8 אותיות קטנות בכ-20 שניות; אבל סיסמה של 12 תווים מכל הסוגים תיקח מיליוני שנים. הסיבה: כל תו נוסף מכפיל את מספר האפשרויות. לכן משפט-סיסמה ארוך עדיף על "Aa1!". קצר. ההגנות הנוספות הן נעילת חשבון אחרי כמה ניסיונות כושלים, ואימות רב-שלבי (MFA) – שילוב של סיסמה עם קוד מהטלפון, כך שגם אם הסיסמה נפרצה התוקף עדיין חסר את הטלפון שלכם.

1.9 ההתקפה שלא צריכה מחשב: הנדסה חברתית

עד כה דיברנו על תקיפה של מכונות. אבל לעיתים קרובות הדרך הקלה ביותר פנימה היא דרך פדאה, לא המחשב. **הנדסה חברתית (Social Engineering)** היא מניפולציה של בני אדם כדי לגרום להם למסור מידע או גישה. אין כאן פריצה טכנית – יש כאן פסיכולוגיה: שילוב של סמכות, דחיפות וסקרנות.

הצורה הנפוצה ביותר היא **Phishing** ("דיג") – דוא"ל או הודעת SMS שמתחזים לגוף לגיטימי (בנק, חברת שליחויות, בית הספר) ומבקשים מכם ללחוץ על קישור או "לאשר פרטים". יש גרסאות ממוקדות יותר: **Spear Phishing** מכוון לאדם מסוים עם פרטים אמיתיים עליו, ו-**Whaling** ("ציד לווייתנים") מכוון למנהלים בכירים. צורות נוספות: **Pretexting** – סיפור כיסוי ("אני מהתמיכה הטכנית, אני צריך את הסיסמה שלך כדי לתקן"), ו-**Baiting** ("פיתיון") – דיסק-און-קי "אבוד" עם תווית מפתה כמו "משכורות", בתקווה שמישהו יחבר אותו למחשב מסקרנות.

2020 – פריצת טוויטר של המפורסמים

קבוצה של בני נוער התקשרה לעובדי חברת טוויטר, התחזתה לצוות ה-IT הפנימי, ושכנעה אותם למסור גישה לכלי הניהול הפנימי. עם הגישה הזו הם השתלטו על חשבונות של ברק אובמה, אילון מאסק, ביל גייטס ואפל, ופרסמו מהם הונאת ביטקוין. הם גרפו כ-118,000 דולר תוך שעות – **בלי לפרוץ אף מחשב**, רק בכוח השכנוע. הסיפור מוכיח שאפילו אחת מחברות הטכנולוגיה הגדולות בעולם נופלת להנדסה חברתית. האדם הוא כמעט תמיד החוליה החלשה.

2016 – המייל ששווה 70 מיליון (Crelan)

עובד במחלקת הכספים של הבנק הבלגי Crelan קיבל מייל "מהמנכ"ל": "אנחנו באמצע עסקה סודית, העבר בבקשה כסף בדחיפות לחשבון הזה, ואל תדבר על זה עם אף אחד". כתובת השולח הייתה כמעט זהה לזו של המנכ"ל האמיתי, בהבדל של אות אחת. הכסף הועבר, והבנק הפסיד כ-70 מיליון אירו. שוב – בלי נזקה

ובלי פריצה, רק שילוב של סמכות, דחיפות וסודיות. שאלה טובה לכיתה: איזה נוהל פשוט היה מונע את זה? (אישור כפול לכל העברה גדולה, ואימות טלפוני בערוץ נפרד.)

איך מזהים הודעת Phishing – סימנים שכדאי ללמד

1. כתובת השולח לא תואמת לארגון (חברת UPS ששולחת מכתובת @2.hotmail.com). תחושת דחיפות או איום ("הצעה אחרונה!", "החשבון ייחסם"). 3. בקשה לאשר פרטים או ללחוץ על כפתור. 4. שגיאות ניסוח או לוגו מטושטש. 5. קישור שהטקסט שלו שונה מהיעד האמיתי (בודקים בריחוף עם העכבר).

1.10 איך מתגוננים: סוגי הבקורות

ראינו הרבה איומים; עכשיו נסדר את ההגנות. כל בקרה (אמצעי הגנה) שייכת לאחת משלוש קטגוריות, ונחזור אליהן בהרחבה בפרק 9:

- **בקרה מנהלית** (Administrative) – מדיניות, נהלים והדרכות. למשל נוהל שאוסר להעביר כסף בלי אישור כפול, או הדרכת עובדים לזהות Phishing. אלה דברים שאנשים עושים.
- **בקרה פיזית** (Physical) – הגנה על החומרה עצמה: מנעול על חדר השרתים, מצלמות אבטחה, שומר בכניסה.
- **בקרה לוגית / טכנית** (Logical) – אמצעים בתוך התוכנה והחומרה: סיסמאות, הצפנה, חומת אש, רשימות גישה (ACL).

שימו לב איך שלוש הקטגוריות עובדות יחד: בסיפור של Crelan, בקרה מנהלית (נוהל אישור כפול) הייתה מונעת את ההונאה, גם בלי שום טכנולוגיה. אבטחה טובה משלבת את שלושתן. כדי לחבר את התיאוריה למעשה, הנה הצעה קטנה קדימה. גם בצידוד רשת של סיסקו יש הגנה מובנית מפני ניחוש סיסמאות, שנלמד לעומק בפרק 2:

```
R1(config)# login block-for 120 attempts 3 within 60
```

! אם היו 3 ניסיונות כושלים תוך 60 שניות – חסום כניסות למשך 120 שניות

1.11 ניהול אבטחה: מדיניות, תקנים ותפקידים

אבטחה אינה רק טכנולוגיה – היא גם ארגון ונהלים. הבסיס לכל ארגון מאובטח הוא **מדיניות אבטחה** (Security Policy): מסמך רשמי שקובע המ מותר ומה אסור (ולא איך – זה תפקיד הנהלים). למשל, מדיניות עשויה לקבוע "כל גישה מרחוק תתבצע דרך VPN בלבד" או "אורך סיסמה מינימלי 12 תווים". בלי מדיניות כתובה אי אפשר לאכוף כלום, וגם קשה לפטר עובד ש"רק בדק" – כי לא הוגדר במפורש שאסור.

סביב המדיניות יש כמה מסמכים משלימים: **נוהל** (Procedure) – הוראות צעד-אחר-צעד ליישום (למשל איך בדיוק מגדירים את ה-VPN; **תקן** (Standard) – דרישה מדידה וברורה (למשל "חובה MFA לכל חשבון מנהל"); **והנחיה** (Guideline) – המלצה גמישה. מסמך חשוב במיוחד הוא **מדיניות שימוש מקובל** (AUP – Acceptable Use Policy), שכל עובד חותם עליו ומגדיר מה מותר לעשות עם ציוד הארגון.

בעולם קיימים **תקנים בינלאומיים** שעוזרים לארגונים לנהל אבטחה בצורה מסודרת. הבולטים: ISO/IEC 27001 – התקן המוביל לניהול אבטחת מידע, שארגונים מקבלים עליו הסמכה; ו-NIST Cybersecurity Framework – מסגרת אמריקאית מקובלת שמחלקת את העבודה לחמישה שלבים: זיהוי, הגנה, גילוי, תגובה, והתאוששות. כדי לעקוב אחר חולשות ידועות משתמשים ב-CVE (Common Vulnerabilities and Exposures) – מאגר עולמי שנותן מזהה לכל פגיעות (למשל CVE-2017-0144, הפגיעות ש-WannaCry ניצל), ולכל אחת ציון חומרה בשם CVSS בסולם 0-10.

ולבסוף, מי אחראי על כל זה בארגון? CISO (Chief Information Security Officer) הוא מנהל אבטחת המידע הבכיר; SOC (Security Operations Center) הוא מרכז ניטור שעובד מסביב לשעון ומזהה אירועים; ו-CERT/CSIRT הוא צוות התגובה לאירועי סייבר. בישראל פועל מערך הסייבר הלאומי ו-CERT-IL.

1.11 אתיקה וחוק – חשוב מאוד

בקורס הזה נלמד איך התקפות עובדות – אבל אך ורק כדי לדעת להתגונן מפניהן. חשוב להבהיר כבר עכשיו: הרצת כלי סריקה או פריצה על רשת שאינה שלכם, וללא אישור בכתב, היא תילילף הריבע לפי **חוק המחשבים**,

התשנ"ה-1995 – גם אם עשיתם זאת "רק כדי לבדוק". הכלים עצמם (כמו Nmap חוקיים לגמרי; מה שאסור הוא השימוש בהם בלי רשות. אם מצאתם חולשה במערכת של מישהו אחר, הדבר הנכון הוא לדווח עליה בלבד (מה שנקרא "גילוי אחראי"), ולא לנצל אותה.

1.12 תרגילים – עם פתרונות

תרגיל 1 – סיווג לפי CIA

לכל אירוע, ציינו איזה עיקרון נפגע: (א) תלמיד מצא דרך לשנות ציון במערכת בית הספר. (ב) אתר ההרשמה של בית הספר קרס ביום ההרשמה. (ג) רשימת הטלפונים של ההורים דלפה לקבוצת וואטסאפ. (ד) כופרה הצפינה את שרת הקבצים.

(א) שלמות (ב) זמינות (ג) סודיות (ד) זמינות (ואם התוקף גם מאיים לפרסם את הקבצים – גם סודיות).

תרגיל 2 – וירוס, תולעת או טרויאני?

(א) משחק "מיינקראפט חנים".exe שמתקין תוכנת ריגול. (ב) קובץ Excel עם מאקרו שמדביק את שאר קובצי ה-Excel כשפותחים אותו. (ג) תוכנה שסורקת את הרשת, מוצאת מחשבים פגיעים ומעתיקה את עצמה אליהם לבד.

(א) סוס טרויאני (המשתמש מתקין מרצון). (ב) וירוס (צריך שיפתחו את הקובץ). (ג) תולעת (מתפשטת לבד).

תרגיל 3 – חוזק סיסמה

מדוע סיסמה של 12 תווים חזקה בהרבה מסיסמה של 8 תווים, גם אם שתיהן משתמשות באותם סוגי תווים? כי כל תו נוסף מכפיל את מספר הצירופים האפשריים. ההפרש בין 8 ל-12 תווים הוא לא "קצת יותר" אלא פי עשרות מיליונים – מה שהופך ניחוש שיטתי (ברוט-פורס) מבלתי-מעשי לחלוטין.

תרגיל 4 – חשיבה על סיפורים אמיתיים

לכל סיפור, איזו בקרה (מנהלית / פיזית / לוגית) הייתה מקטינה את הנזק? (א) WannaCry. (ב) פריצת טוויטר. 2020. (ג) Mirai.

(א) בקרה מנהלית – נוהל עדכונים תקופתי (ולוגית – גיבוי לשחזור). (ב) מנהלית – נוהל שאוסר מסירת גישה בטלפון; לוגית – MFA והרשאות מוגבלות בכלי הניהול. (ג) לוגית – שינוי סיסמת ברירת המחדל של המכשירים.

1.13 מפת הקורס – כל ההגנות שנלמד

סיימנו בסקירת האיומים. שאר הקורס הוא למעשה סדרה של תשובות לאיומים האלה: נתב מוקשח (פרק 2), אימות מרכזי עם מודל AAA (פרק 3), חומות אש ורשימות גישה (פרק 4), מערכות לזיהוי ומניעת חדירה IDS/IPS (פרק 5), אבטחת הרשת המקומית והמתגים (פרק 6), הצפנה (פרק 7), רשתות פרטיות וירטואליות VPN (פרק 8), וניהול סיכונים כולל (פרק 9). כל פרק עונה על איום שראינו כאן.

בנק שאלות שתלמידים שואלים – ותשובות מוכנות

אוסף שאלות שתלמידים סקרנים נוטים לשאול בפרק זה, עם תשובות מוכנות. מסודר לפי נושא – סרקו לפני השיעור.

מוטיבציה ותפיסות שגויות

ש: "אין לי מה להסתיר / אני לא מעניין אף אחד, אז למה שיתקפו אותי?"

ת: רוב ההתקפות אינן ממוקדות אלא תוֹיאֵנוֹטִיסוֹ תוֹיטְמוֹטוּא. גם מחשב "לא מעניין" שווה לתוקף: אפשר להפוך אותו ל-bot ברשת זומבים (פרק 1.4, לגנוב סיסמאות שחוזרות על עצמן באתרים אחרים - credential stuff) ing), להשתמש בו כקרח קפיצה לרשת של בית הספר/ההורים, או להצפין אותו בכופרה ולדרוש כסף. כופרה לא בוררת מטרות.

ש: "אנטי-וירוס מספיק כדי להיות מוגן?"

ת: לא. אנטי-וירוס קלאסי מזהה לפי **חתימות** – תבניות של נזקות תועודי. נזקה חדשה (zero-day) או כזו

ששונתה מעט (polymorphic) לא תזוהה. לכן צריך "הגנה לעומק": עדכוני מערכת, הגנת רשת (חומת אש/IPS), גיבוי, והכי חשוב – משתמש שלא לוחץ על כל דבר.

ש: "מה זה zero-day?"

ת: פגיעות שהיצרן עדיין הילע עדוי אל או שאין לה תיקון – "יום אפס" מאז שהתגלתה. תוקף שמחזיק zero-day יכול לנצל אותה בלי שאף הגנה מבוססת-חתימות תזהה אותה. אלה הפגיעויות היקרות והמסוכנות ביותר.

ש: "האקר = פושע?"

ת: לא בהכרח. White hat – בודק חדירה חוקי, באישור. Black hat – פושע. Gray hat – פורץ ללא אישור אך מדווח. המילה "hacker" במקורה היא מי שמבין מערכות לעומק; התקשורת הצמידה לה משמעות שלילית.

נוזקות

ש: "אז מה בדיוק ההבדל בין וירוס לתולעת? זה מבלבל."

ת: שאלת המפתח: טשפתיש ידכ שמתשמ לש הלועפ רירצ סאה וירוס נדבק לקובץ וזקוק למשתמש שיריץ אותו. תולעת מתפשטת דבל דרך הרשת בלי אף פעולת אדם (למשל תולעת מוריס, Slammer). טרויאני לא משכפל את עצמו כלל – המשתמש מתקין אותו מרצון כי הוא נראה לגיטימי.

ש: "האם מק / לינוקס / אייפון יכולים להידבק בנוזקה?"

ת: כן, כל מערכת יכולה. Windows הוא היעד הנפוץ ביותר כי הוא הכי נפוץ, אבל יש נוזקות ל-macOS, לינוקס, אנדרואיד ו-iOS. אף מערכת אינה "חסונה" – זו תפיסה שגויה מסוכנת.

ש: "כדאי לשלם כופר בכופרה?"

ת: הגישה הרשמית (גם של ה-FBI ומערך הסייבר) היא שלל אל: אין ערובה שתקבלו מפתח, זה מממן פשע, והופך אתכם ליעד חוזר. הפתרון האמיתי הוא גיבוי תקין (פרק 9) שמאפשר לשחזר בלי לשלם.

התקפות והגנה

ש: "אם תוקף מפיל אותנו ב-DDoS, למה שלא פשוט נחסום את הכתובת שלו?"

ת: כי ב-DDoS אין כתובת אחת – ההתקפה מגיעה בו-זמנית מאלפי מכשירים גנועים (botnet) בכל העולם, ולעיתים עם כתובות מקור תופיזם. חסימה ידנית לא מספיקה; צריך סינון בקנה מידה גדול, שירותי ניקוי בענן, rate limiting.

ש: "אדם אחד יכול לבצע DDoS?"

ת: כן – אם הוא שולט ב-botnet (רשת מחשבים גנועים) או שוכר אחד בדארקנט ("DDoS כשירות"). ההבחנה היא לא מספר האנשים אלא מספר תורוקם התעבורה: DoS = מקור אחד, DDoS = מקורות רבים.

ש: "איך phishing עוקף אנטי-וירוס?"

ת: כי לרוב אין בו נוזקה לסרוק – יש רק קישור לאתר מזויף או בקשה להזין פרטים. זו מניפולציה של סדאה, לא של המחשב. אנטי-וירוס לא "רואה" שאתם מקלידים סיסמה באתר מתחזה.

ש: "אם יש נעילה אחרי 3 ניסיונות, למה צריך בכלל סיסמה חזקה?"

ת: כי לא תמיד התוקף עובר דרך מסך ההתחברות. אם דלף סינונתה דסמ של הסיסמאות (גיבובים), התוקף מריץ מיליארדי ניחושים אופליין על החומרה שלו – שם אין נעילה. סיסמה ארוכה הופכת את זה לבלתי מעשי.

ש: "האם זה חוקי להריץ Nmap או להתקין Kali Linux?"

ת: הכלים עצמם חוקיים לחלוטין (זה כמו פטיש). מה שאסור הוא שומישה בהם על רשת שאינה שלכם וללא אישור בכתב – זו עבירה על חוק המחשבים התשנ"ה-1995. ברשת מעבדה מבודדת שלכם – מותר ומומלץ ללמוד.

ש: "מה ההבדל המדויק בין איום, פגיעות וסיכון?"

ת: **איום** = הגורם המסוכן (האקר, שריפה) – קיים תמיד, לא בשליטתנו. **פגיעות** = החולשה שהאיום מנצל (סיסמה חלשה, פורט פתוח) – זה מה שבשליטתנו. **סיכון** = ההסתברות שהאיום ינצל את הפגיעות, כפול הנזק. מנהלים סיכון על ידי צמצום פגיעויות.

מילון מונחים – הגדרות

הגדרות תמציתיות של המונחים המרכזיים בפרק. שימושי גם כדף עזר לבחינה (מותר מילון מונחים).

מונח	הגדרה
אבטחת מידע (Information Security)	הגנה על מידע ומערכות מפני גישה, שינוי, חשיפה או השמדה בלתי מורשים.
אבטחת רשת (Network Security)	תת-תחום: הגנה על תשתית הרשת ועל התעבורה שעוברת בה.

מונח	הגדרה
סודיות (Confidentiality)	הבטחה שרק גורמים מורשים רואים את המידע. מושגת בהצפנה ובבקרת גישה.
שלמות (Integrity)	הבטחה שהמידע לא שונה ללא הרשאה. מושגת בגיבוב וחתומה דיגיטלית.
זמינות (Availability)	הבטחה שהמידע והשירות נגישים כשצריך. נפגעת ב-DoS ובכופרה.
אימות (Authentication)	הוכחת זהות - מי אתה (שם משתמש וסיסמה, ביומטריה).
אי-הכחשה (Non-repudiation)	מניעת אפשרות של השולח להכחיש ששלח; מושגת בחתימה דיגיטלית.
נכס (Asset)	כל דבר בעל ערך שמגנים עליו: מידע, שרת, מוניטין, זמינות.
פגיעות (Vulnerability)	חולשה שניתן לנצל: באג, סיסמה חלשה, פורט פתוח, עובד לא מודרך.
איום (Threat)	גורם שעלול לנצל פגיעות: האקר, נזקה, עובד ממורמר, אסון טבע.
סיכון (Risk)	הסתברות שאיום ינצל פגיעות, כפול הנזק. $\text{סיכון} = \text{איום} \times \text{פגיעות}$ ערך הנכס.
בקרה (Control)	אמצעי שמקטין סיכון. מנהלית (נהלים), פיזית (מנעולים), לוגית (הצפנה, ACL).
נזקה (Malware)	שם כולל לתוכנה זדונית: וירוס, תולעת, טרויאני, כופרה ועוד.
וירוס (Virus)	קוד זדוני שנצמד לקובץ ומתפשט כששתמש מריץ אותו.
תולעת (Worm)	תוכנה שמשכפלת ומתפשטת לבד ברשת, ללא פעולת משתמש.
סוס טרויאני (Trojan)	תוכנה שנראית לגיטימית אך מכילה קוד זדוני; אינה משכפלת את עצמה.
כופרה (Ransomware)	נזקה שמצפינה קבצים ודורשת תשלום; פוגעת בזמינות.
Rootkit	נזקה שמסתתרת עמוק במערכת ההפעלה ומסווה נזקות אחרות.
Botnet	רשת מחשבים נגועים (זומבים) הנשלטים מרחוק לביצוע התקפות.
Backdoor	דלת אחורית שעוקפת את מנגנון האימות ומאפשרת גישה סמויה.
הנדסה חברתית (Social Engineering)	מניפולציה של בני אדם כדי להשיג מידע או גישה (במקום פריצה טכנית).
Phishing	דוא"ל/הודעה מתחזים המבקשים ללחוץ על קישור או למסור פרטים.
DoS / DDoS	מניעת שירות - הצפת שירות עד קריסה, ממקור אחד (DoS) או ממקורות רבים (DDoS).
SYN flood	הצפת שרת בבקשות SYN חצי-פתוחות עד שטבלת החיבורים מתמלאת.
Buffer overflow	שליחת קלט ארוך מהחוצץ, שגולש ודורס זיכרון ומריץ קוד תוקף.
Brute force	ניסוי שיטתי של כל הסיסמאות האפשריות (או רשימת מילון) עד למציאה.
Reconnaissance	שלב הסיור - איסוף מידע על המטרה (whois, sniffing), סריקת פורטים.
Zero-day	פגיעות שאין לה עדיין תיקון או שאינה ידועה ליצרן.